



AMPERÊ

NILM CONTROL

Governança, Segurança da Informação e Aquisição de Usuários

FIAP · Startup One · Fase 6 · Startup Cybersecurity Governance

Grupo SenseForge · 4SIOA

Guilherme Costa Proença (RM 98937) · Eduarda Quagliareli Shiratsu (RM 551188) · Hugo Antônio de Oliveira (RM 550153)
Outubro de 2026

Identificação da entrega

Startup	Amperê — monitoramento de energia residencial por aparelho (NILM)
Aplicação publicada	https://ampere-dashboard-six.vercel.app
Repositório	https://github.com/GuilhermeCostaProenca/ampere-dashboard
Vídeo-pitch (não listado)	https://youtu.be/L-FT-pk3LX8
Banco de dados	PostgreSQL gerenciado — Supabase, região us-west-2

Sumário

Parte 1 — Revisão do MVP

- 1.1 Estado atual
- 1.2 O que foi melhorado desde a fase anterior
- 1.3 Melhorias pretendidas

Parte 2 — Planejamento de adequação à LGPD

- 2.1 Dados coletados e justificativa
- 2.2 Bases legais
- 2.3 Encarregado (DPO)
- 2.4 Controles técnicos
- 2.5 Controles organizacionais
- 2.6 Operadores e transferência internacional
- 2.7 Comunicação com titulares e incidentes

Parte 3 — Governança de TI (ISO/IEC 38500)

- 3.1 Os seis princípios aplicados à startup
- 3.2 Boas práticas de governança
- 3.3 Ciclo Avaliar–Dirigir–Monitorar

Parte 4 — Segurança e auditoria da solução

- 4.1 Superfície de ataque
- 4.2 Riscos identificados e OWASP Top 10
- 4.3 Controles propostos
- 4.4 Como a solução pode ser auditada
- 4.5 Relação com a família ISO 27000

Parte 5 — Divulgação e aquisição de usuários

- 5.1 Palavras-chave
- 5.2 Ações de SEO
- 5.3 Canais de divulgação
- 5.4 Estratégia de Inbound Marketing
- 5.5 Acompanhamento de resultados

Parte 1 — Revisão do MVP

1.1 Estado atual

O Amperê é um sistema de monitoramento energético residencial baseado em NILM (*Non-Intrusive Load Monitoring*): um único sensor de corrente instalado no quadro elétrico mede o consumo total da casa, e o software separa desse sinal o consumo de cada aparelho, apresentando o resultado em reais.

O MVP está publicado e funcional, com as seguintes camadas:

CAMADA	TECNOLOGIA	SITUAÇÃO
Dispositivo	ESP32 + sensor SCT-013-030	Em montagem; substituído hoje por um simulador que publica no mesmo endpoint, formato e autenticação previstos para o firmware
API	Node.js, Express e TypeScript	Publicada como função serverless na Vercel
Desagregação	Detector NILM por degraus de potência, isolado atrás de uma interface	Recall de 93,6% e precisão de 99,0% em janela de 30 dias de dados
Banco	PostgreSQL gerenciado no Supabase, Star Schema com 6 dimensões e 2 fatos	8 migrations aplicadas, RLS habilitado em todas as tabelas
Front-end	React, Vite e TypeScript	Publicado na Vercel, consumindo a API na mesma origem

1.2 O que foi melhorado desde a fase anterior

Na entrega anterior o sistema rodava apenas em ambiente local. Nesta fase o projeto foi efetivamente publicado e corrigido:

- **Publicação em nuvem.** Front-end e API passaram a ser servidos na mesma origem pela Vercel, com a aplicação Express exportada como função serverless (`api/index.ts`). Isso eliminou a necessidade de um segundo provedor e removeu a configuração de CORS entre domínios diferentes.
- **Correção do roteamento de produção.** O `vercel.json` passou a reescrever `/api/(.*)` para a função única, em vez de depender da convenção de *catch-all* de framework, que casava apenas um segmento de caminho e derrubava rotas como `/api/auth/login`.
- **Correção do CORS para mesma origem.** A checagem passou a comparar o *host* do cabeçalho `Origin` com o *host* da requisição. Antes, a API recusava o próprio front e a recusa virava erro 500 em vez de bloqueio de CORS.
- **Diagnóstico de configuração.** Variáveis de ambiente ausentes passaram a produzir resposta 503 legível, nomeando o que falta, em vez de erro 500 opaco.
- **Landing page pública.** Foi criada uma página de entrada antes do painel, com o problema, o funcionamento do NILM, o produto e os planos — base para a estratégia de aquisição descrita na Parte 5.
- **Correção da documentação.** O README descrevia uma arquitetura com API em outro provedor, que nunca chegou a existir. Foi corrigido para refletir a arquitetura real.

Princípio adotado. O simulador publica no mesmo endpoint, com o mesmo formato e a mesma autenticação previstos para o firmware. Quando o hardware físico entrar, nada muda do backend para a frente: o contrato de dados é idêntico.

1.3 Melhorias pretendidas

MELHORIA	MOTIVAÇÃO	HORIZONTE
Montagem do hardware físico (ESP32 + SCT-013)	Substituir o simulador por leitura real de corrente	Curto
Limitação de taxa nas rotas de autenticação e ingestão	Risco R2 da Parte 4 — hoje não há proteção contra força bruta ou abuso	Curto
Registro de auditoria de acessos e operações sensíveis	Risco R6 da Parte 4 e exigência de rastreabilidade da LGPD	Curto
Hash da chave de ingestão e rotação de chaves por dispositivo	Risco R3 da Parte 4	Médio
Substituição do detector heurístico por modelo treinado de NILM	Ganho de acurácia em cargas simultâneas e de baixa potência	Médio
Piloto em condomínio	Validação do canal B2B e medição da economia real gerada	Médio

Parte 2 — Planejamento de adequação à LGPD

2.1 Dados coletados e justificativa

O levantamento abaixo foi feito a partir do schema efetivamente aplicado no banco (`supabase/migrations/`), e não de uma previsão.

DADO	ONDE	JUSTIFICATIVA DA COLETA
Nome	<code>dim_usuario.nome</code>	Identificação do titular na interface e na comunicação
E-mail	<code>dim_usuario.email</code>	Credencial de acesso, recuperação de conta e envio de alertas de consumo
Tipo de imóvel (apartamento ou casa)	<code>dim_usuario.tipo_imovel</code>	Calibra o perfil de carga esperado e melhora a desagregação NILM
Plano contratado	<code>dim_usuario.plano</code>	Controle de acesso às funcionalidades do plano Pro
Senha	Supabase Auth (fora das tabelas da aplicação)	Autenticação; armazenada com hash pelo provedor de identidade
Identificador, apelido, versão de firmware, intensidade de sinal e chave de ingestão do dispositivo	<code>dim_dispositivo</code>	Vínculo do equipamento ao titular, suporte técnico e autenticação da telemetria
Leituras de potência agregadas a cada 15 minutos	<code>fato_leitura_agregada</code>	Matéria-prima do serviço: sem a série temporal não há desagregação nem custo por aparelho
Eventos de aparelho identificados pelo NILM (aparelho, instante, duração, confiança)	<code>fato_evento_aparelho</code>	Entrega central do produto: o custo em reais por aparelho

Ponto crítico de privacidade. A curva de consumo elétrico de uma residência não é um dado sensível na definição do art. 5º, II da LGPD, mas tem potencial inferencial alto: revela rotina de sono, horários de banho, presença ou ausência de pessoas em casa e número aproximado de moradores. O Amperê trata esses dados **como se fossem sensíveis**: minimização de granularidade (agregação em janelas de 15 minutos, nunca amostra instantânea bruta), proibição de compartilhamento com terceiros e vedação expressa de venda de dados de consumo, que fica registrada na política de privacidade.

2.2 Bases legais

TRATAMENTO	BASE LEGAL (ART. 7º DA LGPD)	OBSERVAÇÃO
Cadastro, autenticação e manutenção da conta	Inciso V — execução de contrato	Sem esses dados não há como prestar o serviço contratado
Coleta e processamento da telemetria de consumo	Inciso V — execução de contrato	É a função essencial do produto, descrita no momento da contratação
Alertas de consumo e comunicações operacionais	Inciso V — execução de contrato	Parte da entrega; distinto de marketing
Registros de acesso e medidas antifraude	Inciso IX — legítimo interesse, e art. 15 da Lei 12.965/2014 (Marco Civil) para registros de aplicação	Exige teste de balanceamento documentado e minimização dos registros
Comunicação de marketing e newsletter	Inciso I — consentimento	Consentimento separado, específico e revogável a qualquer momento
Uso de dados agregados e anonimizados para melhoria do modelo NILM	Art. 12 — dado anonimizado fora do escopo da lei; na dúvida, inciso I	A anonimização precisa ser irreversível por meios razoáveis; curva de consumo é reidentificável, então o padrão adotado é pedir consentimento

2.3 Encarregado (DPO)

Sim, haverá nomeação. Em uma startup de três pessoas não se justifica um encarregado dedicado, e a LGPD não exige que seja pessoa externa ou em tempo integral.

- **Encarregado designado:** Guilherme Costa Proença, responsável técnico pela arquitetura e pelo banco de dados, com acesso para executar requisições de titulares (acesso, correção, portabilidade e eliminação).
- **Canal público:** endereço `privacidade@ampere.app`, divulgado na política de privacidade e no rodapé da landing page, conforme art. 41, §1º.
- **Atribuições:** receber comunicações de titulares e da ANPD, orientar a equipe sobre práticas de proteção de dados e manter o registro das operações de tratamento.
- **Conflito de interesse:** por acumular a função técnica, o encarregado não decide sozinho sobre incidentes — a comunicação de incidente exige aprovação dos três sócios, o que fica registrado na política interna.

2.4 Controles técnicos

CONTROLE	SITUAÇÃO
Autenticação por token do provedor de identidade (Supabase Auth), validado a cada requisição	Implementado
Row Level Security habilitado em todas as 8 tabelas, com política por <code>auth.uid()</code>	Implementado
Autenticação própria do dispositivo por chave dedicada, separada da sessão do usuário	Implementado
Validação de esquema em toda entrada da API (Zod), com limite de 500 leituras por lote e teto de potência	Implementado
CORS restrito às origens autorizadas	Implementado
Segredos fora do repositório, em variáveis de ambiente do provedor; <code>.gitignore</code> cobrindo <code>.env</code>	Implementado
Tráfego cifrado em trânsito (TLS) e em repouso pelo provedor gerenciado	Implementado
Minimização: telemetria agregada em 15 minutos; nenhum dado de localização, documento ou pagamento é coletado	Implementado
Limitação de taxa nas rotas de autenticação e ingestão	Pendente — ver R2
Hash da chave de ingestão e política de rotação	Pendente — ver R3
Trilha de auditoria de acessos e exclusões	Pendente — ver R6
Política de retenção: telemetria detalhada por 24 meses, depois agregação mensal; exclusão total em até 30 dias após pedido do titular	Definida, implementação pendente

2.5 Controles organizacionais

- Política de privacidade e termos de uso publicados antes da abertura do cadastro ao público.
- Registro das operações de tratamento (art. 37), mantido como documento versionado no repositório.
- Relatório de impacto à proteção de dados pessoais (RIPD) para a telemetria, dado o potencial inferencial descrito em 2.1.
- Acesso ao banco de produção restrito ao encarregado; os demais integrantes trabalham com ambiente de desenvolvimento e dados sintéticos.
- Revisão de código obrigatória para alterações que toquem autenticação, RLS ou rotas de dados pessoais.
- Procedimento escrito de resposta a incidentes, com papéis definidos e prazos da seção 2.7.

2.6 Operadores e transferência internacional

O Amperê é controlador. Dois operadores participam do tratamento, ambos com infraestrutura fora do Brasil, o que caracteriza transferência internacional (art. 33):

OPERADOR	PAPEL	LOCAL	INSTRUMENTO
Supabase	Banco de dados e identidade	Estados Unidos (us-west-2)	Cláusulas contratuais do fornecedor e adendo de proteção de dados
Vercel	Hospedagem do front e da API	Estados Unidos	Cláusulas contratuais do fornecedor e adendo de proteção de dados

Como os Estados Unidos não constam da lista de países com grau de proteção adequado reconhecido pela ANPD, a base da transferência são as cláusulas-padrão contratuais, e o fato precisa estar declarado na política de privacidade. Avaliação prevista: migrar a região do banco para São Paulo, o que elimina a transferência e reduz latência.

2.7 Comunicação com titulares e incidentes

EXERCÍCIO DE DIREITOS

- Canal único em `privacidade@ampere.app`, além de exclusão de conta pela própria tela de configurações.
- Confirmação de recebimento imediata e resposta conclusiva em até 15 dias (art. 19, II).
- Portabilidade atendida por exportação da telemetria e dos eventos em CSV e JSON.
- A exclusão apaga o usuário na identidade e, por cascata de chave estrangeira, dispositivos, aparelhos e fatos vinculados.

INCIDENTES DE SEGURANÇA

O procedimento segue a Resolução CD/ANPD nº 15/2024: comunicação à ANPD e aos titulares afetados em até **três dias úteis** contados do conhecimento do incidente, quando houver risco ou dano relevante aos titulares.

1. **Detecção e contenção** — revogação de chaves e sessões, bloqueio do vetor.
2. **Avaliação de risco relevante** — categorias e volume de dados atingidos, número de titulares, se os dados estavam cifrados e medidas já aplicadas.
3. **Comunicação** — formulário da ANPD e aviso direto por e-mail aos titulares, em linguagem simples, descrevendo o que ocorreu, quais dados foram atingidos, os riscos e as medidas tomadas.
4. **Registro e correção** — todo incidente é registrado, inclusive os que não exigem comunicação, com a correção que o originou.

Parte 3 — Governança de TI (ISO/IEC 38500)

3.1 Os seis princípios aplicados à startup

PRINCÍPIO	REALIDADE DA STARTUP	ENCAMINHAMENTO
Responsabilidade	Três sócios acumulam papéis: não há separação formal entre quem decide, quem constrói e quem opera	Matriz de responsabilidade escrita: arquitetura e banco com Guilherme; produto e negócio com Eduarda; comunicação e conteúdo com Hugo. Decisões de risco são colegiadas
Estratégia	As escolhas técnicas já seguem a estratégia: NILM isolado atrás de interface porque o roadmap prevê trocar a heurística por modelo treinado	Revisão trimestral do roadmap técnico contra o roadmap de negócio, com decisões registradas
Aquisição	Toda a infraestrutura usa camada gratuita de provedores gerenciados, escolha feita por custo e velocidade, sem análise formal	Critério escrito de escolha de fornecedor: custo, portabilidade dos dados, conformidade com a LGPD e risco de dependência. O fato de o banco ter sido pausado automaticamente por inatividade mostra o risco concreto do plano gratuito em produção
Desempenho	Há medição da qualidade do NILM (recall e precisão), mas não há monitoramento de disponibilidade nem de latência	Definir indicadores mínimos: disponibilidade da API, latência da ingestão, taxa de erro e atraso de telemetria por dispositivo
Conformidade	LGPD é a exigência imediata; o produto também toca normas de instalação elétrica no hardware	Plano da Parte 2 como base, mais verificação de conformidade elétrica antes da venda do kit
Comportamento humano	O produto observa rotina doméstica; o teste de usabilidade mostrou que o usuário procura primeiro o maior gasto	Decisões de produto passam por duas perguntas: o usuário entende o que está sendo coletado, e a informação leva a uma ação útil em vez de culpa

3.2 Boas práticas de governança

- **Infraestrutura como código versionado.** O schema do banco já vive em migrations no repositório; nenhuma alteração é feita direto no painel do provedor.
- **Separação de ambientes.** Desenvolvimento com dados sintéticos e produção com dados reais, com credenciais distintas.
- **Revisão por pares** obrigatória em alterações de autenticação, RLS e rotas de dados pessoais.
- **Registro de decisões de arquitetura** em documento curto por decisão, com alternativa descartada e motivo.
- **Gestão de acessos** com princípio do menor privilégio e revisão semestral de quem tem acesso a quê.
- **Plano de continuidade:** backup verificado do banco e procedimento testado de restauração.

3.3 Ciclo Avaliar–Dirigir–Monitorar

ETAPA	APLICAÇÃO CONCRETA NO AMPERÊ	CADÊNCIA
Avaliar	Analisar o uso atual e previsto de TI: custo da infraestrutura por usuário ativo, riscos da Parte 4, acurácia do NILM e dependência de fornecedores	Mensal
Dirigir	Decidir e comunicar: priorizar na sprint os controles pendentes (limitação de taxa, trilha de auditoria, hash da chave de ingestão), definir política de retenção e aprovar a migração de região do banco	A cada sprint
Monitorar	Acompanhar o cumprimento: painel de indicadores de disponibilidade e latência, relatório de advisors de segurança do provedor, resultado de <code>npm audit</code> e registro de pedidos de titulares atendidos no prazo	Contínuo, com revisão mensal

O ciclo não é um anexo burocrático: o incidente de o banco ter sido pausado por inatividade seria detectado na etapa de monitoramento, por verificação automática do endpoint de saúde, e tratado na etapa de direção com a decisão sobre plano pago ou verificação periódica.

Parte 4 — Segurança e auditoria da solução

4.1 Superfície de ataque



A análise abaixo foi feita por leitura do código publicado no repositório, e não por suposição: cada risco aponta o arquivo onde a condição existe.

4.2 Riscos identificados e relação com o OWASP Top 10

#	RISCO	EVIDÊNCIA	OWASP	SEV.
R1	O backend acessa o banco com a chave <code>service_role</code> , que contorna o RLS por definição. O escopo por usuário depende de cada query lembrar de filtrar por <code>usuario_id</code> . Um filtro esquecido expõe dados de todos os usuários, e o RLS não serve de rede de proteção	<code>server/src/lib/supabase.ts</code>	A01 — Quebra de controle de acesso	ALTA
R2	Nenhuma limitação de taxa em <code>/auth/login</code> , <code>/auth/signup</code> ou <code>/ingest/readings</code> . Permite força bruta de senha, enumeração de contas e inundação da ingestão, que também gera custo no provedor	<code>server/src/app.ts</code> — sem middleware de <code>rate limit</code>	A07 — Falhas de identificação e autenticação; A04 — Design inseguro	ALTA
R3	Chave de ingestão armazenada em texto puro na coluna <code>chave_ingestao</code> , sem rotação, sem expiração e sem revogação. Quem obtiver leitura dessa tabela ou acesso ao firmware injeta telemetria falsa indefinidamente	<code>migrations/20260828120000</code> , <code>middleware/auth.ts</code>	A02 — Falhas criptográficas	ALTA
R4	Cadastro cria a conta com <code>email_confirm: true</code> , sem verificação do endereço. Permite criar conta com e-mail de terceiro e recebe alertas de consumo de outra pessoa	<code>server/src/routes/auth.routes.ts</code>	A07 — Falhas de identificação e autenticação	MÉDIA
R5	Senha mínima de 6 caracteres, sem verificação contra listas de senhas vazadas e sem segundo fator	<code>cadastroSchema</code> em <code>auth.routes.ts</code>	A07 — Falhas de identificação e autenticação	MÉDIA
R6	Não há trilha de auditoria. O registro existente é apenas <code>console.log</code> de inicialização e de seed, sem retenção. Um acesso indevido não deixa rastro e um incidente não pode ser reconstruído — o que também inviabiliza a avaliação exigida pela LGPD	<code>server/src/</code> — ausência de camada de log estruturado	A09 — Falhas de registro e monitoramento	ALTA
R7	Requisição sem cabeçalho <code>Origin</code> é liberada por decisão de projeto, para atender curl, ESP32 e verificação de saúde. É correto para a ingestão, mas combinado com a ausência de limitação de taxa amplia a superfície de abuso	<code>server/src/app.ts</code>	A05 — Configuração incorreta de segurança	MÉDIA
R8	Não há varredura automatizada de dependências nem processo definido de atualização; nenhuma verificação roda antes da publicação	Ausência de integração contínua no repositório	A06 — Componentes vulneráveis e desatualizados	MÉDIA
R9	A publicação ocorre automaticamente a partir do ramo principal, sem proteção de ramo, sem revisão obrigatória e sem verificação de integridade. Um commit indevido vai a produção sem barreira	Configuração do projeto na Vercel	A08 — Falhas de integridade de software e dados	MÉDIA
R10	Disponibilidade: o projeto do banco está em plano gratuito e é pausado automaticamente após período de inatividade, derrubando a aplicação inteira sem aviso	Status do projeto no provedor	A04 — Design inseguro (resiliência)	ALTA

RISCOS AVALIADOS E CONSIDERADOS BAIXOS

- **A03 — Injeção:** todo acesso ao banco passa pelo cliente oficial, que parametriza as consultas, e toda entrada é validada por esquema antes de chegar à camada de dados. Não há concatenação de SQL com dado do usuário.
- **A10 — Falsificação de requisição no servidor (SSRF):** a API não busca URLs fornecidas pelo usuário; não há vetor.

Verificação independente. A análise de segurança automatizada do provedor de banco de dados (*security advisors* do Supabase) foi executada sobre o projeto em produção e não retornou nenhum apontamento. Isso confirma que o *Row Level Security* está habilitado com política em todas as tabelas — e delimita com precisão o risco R1: o problema não é a configuração do banco, que está correta, mas o fato de o backend acessá-lo com uma chave que, por definição, passa por cima dela.

4.3 Controles propostos

RISCO	CONTROLE	PRIORIDADE
R1	Centralizar o acesso ao banco em funções que exigem o identificador do usuário como parâmetro obrigatório, tornando impossível montar a consulta sem o filtro; adicionar teste automatizado que tenta ler dado de outro usuário e deve falhar; avaliar migração para cliente autenticado com o token do próprio usuário, deixando o RLS como barreira efetiva	Imediata
R2	Limitação de taxa por IP nas rotas de autenticação (por exemplo, 5 tentativas por minuto, com atraso progressivo) e por chave de dispositivo na ingestão; bloqueio temporário após repetição	Imediata
R3	Armazenar apenas o hash da chave de ingestão; emitir a chave uma única vez no provisionamento; permitir revogação e rotação por dispositivo na tela de configurações	Alta
R4	Ativar confirmação de e-mail antes de liberar o painel	Alta
R5	Elevar o mínimo para 10 caracteres, verificar contra lista de senhas vazadas e oferecer segundo fator	Média
R6	Registro estruturado de autenticação, ingestão, alteração de plano e exclusão de conta, com identificador do usuário, data e origem, retido por 6 meses e protegido contra alteração	Imediata
R7	Manter a liberação apenas para a rota de ingestão, exigindo a chave de dispositivo, e recusar requisição sem origem nas demais rotas	Média
R8	Verificação automática de dependências a cada alteração e atualização mensal programada	Média
R9	Proteção do ramo principal, revisão obrigatória por outro integrante e publicação a partir de versão marcada (<i>tag</i>)	Média
R10	Verificação automática do endpoint de saúde com alerta, e migração para plano pago antes do piloto em condomínio	Imediata

4.4 Como a solução pode ser auditada

OBJETO DA AUDITORIA

DIMENSÃO	O QUE SE VERIFICA	FONTE DE EVIDÊNCIA
Acessos de usuário	Quem entrou, quando, de onde, e se houve tentativa falha repetida	Registros do provedor de identidade e trilha de auditoria da aplicação (controle R6)
Acessos privilegiados	Quem tem acesso ao banco de produção e às variáveis de ambiente, e se a lista corresponde à matriz de responsabilidade	Painel dos provedores, revisado semestralmente
Controle de acesso a dados	Se o RLS está habilitado e com política em todas as tabelas, e se nenhuma consulta do backend omite o filtro por usuário	Migrations versionadas, relatório de advisors do provedor e teste automatizado de isolamento
Integridade da telemetria	Se toda leitura gravada veio de uma chave de dispositivo válida e vinculada a um usuário	Encadeamento entre <i>fato_leitura_agregada</i> , <i>dim_dispositivo</i> e <i>dim_usuario</i>
Alterações de esquema	Se toda mudança no banco tem migration correspondente, revisada e datada	Histórico do repositório; alteração manual no painel é desvio e precisa ser justificada
Conformidade com a LGPD	Se pedidos de titulares foram atendidos em 15 dias e se a retenção está sendo aplicada	Registro de pedidos mantido pelo encarregado
Dependências e publicação	Se há vulnerabilidade conhecida em biblioteca e se o que está publicado corresponde a uma versão marcada	Relatório da verificação de dependências e histórico de publicações

ROTINA

- **Contínua e automática:** verificação de dependências e do endpoint de saúde a cada alteração.
- **Mensal:** leitura dos advisors de segurança do provedor e revisão da trilha de auditoria em busca de padrão anômalo.
- **Semestral:** revisão de acessos privilegiados e teste de restauração de backup.
- **Sob demanda:** auditoria completa após qualquer incidente, com relatório registrado.

4.5 Relação com a família ISO 27000

MEDIDA PROPOSTA	REFERÊNCIA
Política de segurança da informação e definição de papéis	ISO/IEC 27001, cláusula 5; ISO/IEC 27002 — políticas e responsabilidades
Processo de identificação, análise e tratamento dos riscos R1 a R10, com registro de riscos aceitos	ISO/IEC 27001, cláusula 6; ISO/IEC 27005 — gestão de riscos
Controle de acesso, menor privilégio e revisão periódica de acessos privilegiados	ISO/IEC 27002 — controle de acesso e gestão de acessos privilegiados
Autenticação segura: senha forte, confirmação de e-mail, segundo fator e rotação de chave de dispositivo	ISO/IEC 27002 — autenticação segura e gestão de informações de autenticação
Registro de eventos, proteção dos registros e monitoramento	ISO/IEC 27002 — registro de eventos e atividades de monitoramento
Verificação de dependências e correção de vulnerabilidades conhecidas	ISO/IEC 27002 — gestão de vulnerabilidades técnicas
Revisão de código, proteção de ramo e separação de ambientes	ISO/IEC 27002 — desenvolvimento seguro e separação de ambientes
Gestão de incidentes, com avaliação, comunicação e aprendizado	ISO/IEC 27002 — gestão de incidentes de segurança da informação
Avaliação de segurança no uso de serviços em nuvem e cláusulas com os operadores	ISO/IEC 27002 — segurança no uso de serviços em nuvem; ISO/IEC 27017
Proteção de dados pessoais tratados em nuvem e gestão de privacidade	ISO/IEC 27018; ISO/IEC 27701
Cópias de segurança e teste de restauração	ISO/IEC 27002 — cópias de segurança

Parte 5 — Divulgação e aquisição de usuários

5.1 Palavras-chave

A seleção parte da linguagem do próprio público: na pesquisa de campo do grupo, com 18 respondentes, 78% não sabem quais aparelhos mais consomem, 89% não conseguem quantificar esse consumo e 83% já se surpreenderam com a conta. Quem tem esse problema não busca por "NILM" — busca pela dor.

GRUPO	TERMOS	INTENÇÃO
Dor imediata	conta de luz alta; por que minha conta de luz aumentou; como economizar energia em casa	Informação — topo de funil, alto volume
Consumo por aparelho	quanto gasta um chuveiro elétrico; quanto consome ar-condicionado por hora; qual aparelho gasta mais energia	Informação com intenção específica — é exatamente o que o produto responde
Solução	medidor de consumo de energia residencial; monitor de energia wi-fi; como saber o gasto de cada aparelho	Comparação — meio de funil
Produto	Amperê monitor de energia; sensor de energia para quadro elétrico; preço monitor de consumo	Transação — fundo de funil
Técnico e B2B	NILM monitoramento não intrusivo de carga; gestão de energia em condomínio; medição individualizada condomínio	Nicho de baixo volume e alta qualificação

5.2 Ações de SEO

DENTRO DA PÁGINA

- Título e descrição da landing escritos para a dor, não para a tecnologia: "Descubra quanto cada aparelho pesa na sua conta de luz".
- Um H1 único por página e uma hierarquia de títulos que espelhe as perguntas do usuário.
- Página dedicada por aparelho de alto consumo (chuveiro, ar-condicionado, geladeira), cada uma respondendo à pergunta de busca com cálculo real e tarifa vigente.
- Dados estruturados `schema.org`: *Product* para o kit, *FAQPage* para as dúvidas e *Organization* para a marca.
- Texto alternativo descritivo nas imagens do produto e do quadro elétrico.

TÉCNICO

- `sitemap.xml` e `robots.txt`, hoje inexistentes no projeto.
- Desempenho: o front já é estático e servido por CDN; manter o maior elemento visível carregando rápido, servindo as imagens do produto em formato moderno e em tamanhos adequados, como já é feito com as mídias em `public/midia/`.
- URLs legíveis e estáveis, idioma declarado e página de erro útil.
- HTTPS e domínio próprio: trocar o endereço provisório do provedor por um domínio da marca antes de investir em conteúdo.

FORA DA PÁGINA

- Conteúdo técnico sobre NILM publicado em comunidades de desenvolvimento, com link para a landing.
- Parcerias com portais de eficiência energética e de administração de condomínios.
- Perfil da empresa no Google, relevante para a busca local quando houver instalação assistida.

5.3 Canais de divulgação

CANAL	PAPEL	FORMATO
Instagram e TikTok	Alcance e descoberta	Vídeo curto do tipo "quanto custa seu banho": medição real de um chuveiro, com o valor em reais na tela
YouTube	Consideração	Instalação do sensor em dois minutos, e explicação do NILM em linguagem simples
Busca orgânica	Aquisição contínua	Páginas por aparelho e calculadoras, conforme 5.2
Síndicos e administradoras	Canal B2B, o de maior valor por contato	Apresentação em assembleia, piloto em um condomínio e indicação a partir dele
Grupos de moradores em aplicativos de mensagem	Indicação entre vizinhos	Programa de indicação com desconto para quem indica e para quem é indicado
Comunidades de automação residencial	Primeiros usuários técnicos, que geram prova e correção de defeitos	Participação honesta, sem anúncio disfarçado
Mídia paga	Validação de mensagem, com orçamento	Campanha de busca sobre os termos de fundo de funil

5.4 Estratégia de Inbound Marketing

A isca precisa entregar, de graça, uma versão pequena do que o produto entrega: a resposta para "quanto isso me custa".

1. **Atrair.** Calculadora gratuita na landing: o visitante escolhe o aparelho, informa o tempo de uso e a tarifa, e recebe o custo mensal. Responde à busca e demonstra a proposta de valor sem exigir cadastro.
2. **Converter.** Para receber o resultado detalhado por e-mail, o visitante deixa o endereço, com consentimento específico para comunicação de marketing, conforme a Parte 2.
3. **Relacionar.** Sequência de quatro e-mails: os cinco aparelhos que mais pesam na conta; como a bandeira tarifária muda o valor; o que é NILM em linguagem simples; e o convite para o plano gratuito.
4. **Encantar.** Relatório mensal do próprio consumo, que é o produto, mais um programa de indicação. O usuário satisfeito é o canal mais barato em um produto que depende de confiança para entrar na casa de alguém.

Coerência com a Parte 2. Nenhuma ação de marketing usa dado de consumo de usuário real. A calculadora trata dados informados avulsos, e o disparo de e-mails depende de consentimento específico e revogável, separado do aceite dos termos de uso.

5.5 Acompanhamento de resultados

ETAPA	INDICADOR	FERRAMENTA	META INICIAL
Atração	Sessões orgânicas e posição média nos termos-alvo	Google Search Console e analítica da web	Primeira página em três termos de cauda longa em 90 dias
Engajamento	Uso da calculadora por sessão	Evento próprio na analítica	25% dos visitantes da landing
Conversão	Visitante que vira cadastro	Analítica e banco da aplicação	3% a 5%
Ativação	Cadastro que conecta um dispositivo e recebe telemetria	<code>dim_dispositivo.ultimo_contato</code>	60% dos cadastros
Retenção	Usuário ativo no sétimo e no trigésimo dia	Banco da aplicação	40% no trigésimo dia
Receita	Conversão do plano gratuito para o Pro, e custo de aquisição por canal	Banco e planilha de campanha	Custo de aquisição abaixo da margem de contribuição projetada no CP5
Reputação	Menções e avaliações	Alertas de busca e redes	Acompanhamento qualitativo semanal

A medição usa os próprios dados da aplicação sempre que possível, o que evita ferramenta adicional tratando dado pessoal — decisão alinhada ao princípio de minimização da Parte 2.

Encerramento

Esta fase deslocou o projeto de "o sistema funciona" para "o sistema é confiável e pode ser auditado". O levantamento da Parte 4 foi feito sobre o código publicado, e por isso apontou riscos reais e ainda abertos, e não uma lista genérica: a chave de serviço que contorna o controle de acesso por linha, a ausência de limitação de taxa, a chave de dispositivo em texto puro e a falta de trilha de auditoria. Todos estão priorizados no roadmap da seção 1.3.

A escolha de registrar o que ainda não está pronto é deliberada. Um plano de segurança que só descreve o que já funciona não serve para nada — nem para investidor, nem para o usuário que vai deixar um sensor lendo a rotina da própria casa.

Repositório	https://github.com/GuilhermeCostaProenca/ampere-dashboard
Aplicação	https://ampere-dashboard-six.vercel.app
Vídeo-pitch (não listado)	https://youtu.be/L-FT-pk3LX8